VULNERABILITY SCANNING

WyIT 3020

PURPOSE: This policy states that the CIO will utilize automated tools to scan systems, computing and network devices, web applications, and application code.

The results of these scans help inform management and system administrators of known and potential vulnerabilities.

I. APPLICABILITY

This policy applies to all Executive Branch agencies, boards, and commissions staff (collectively referred to as "agencies"). This policy is also applicable to consultants, affiliates, and temporary employees.

II. DEFINITIONS

All definitions for this policy are located in the Policy Dictionary.

III. EXCEPTIONS

Any exceptions provided to the following policy must abide by the WyIT - 3002 - Security Exception Request policy.

IV. REQUIREMENTS

Vulnerability management is a process by which risks are identified via scanning and are tracked, evaluated, prioritized, and managed until the vulnerabilities are remediated. Managing the vulnerabilities identified during scans ensures that appropriate actions are taken to reduce the potential that these vulnerabilities are exploited through intentional or unintentional actions and thereby reduce the risk of compromise to the confidentiality, integrity, and availability of information assets.

V. TYPES OF SCANS

The type of vulnerability scan appropriate for a given target depends on the target type (e.g., hardware, software, or source code) and the target's location (e.g., internal or external to the network). The table below lists the types of vulnerability scans required by this policy.

TYPE	DESCRIPTION
External Infrastructure Scan	Scans of the perimeter of the network or any externally available hosted infrastructure to identify potential vulnerabilities in Internet-accessible IT infrastructure.
Internal Infrastructure Scan	Scans of IT infrastructure on protected networks or any hosted infrastructure to identify potential vulnerabilities.
"Lite" Web Application Scan	Cursory unauthenticated scans of externally facing production web applications to identify security vulnerabilities.
In-depth Web Application Scan	When implemented, authenticated in-depth scans of web applications to identify security vulnerabilities.

VI. SCANNING

- The CIO is responsible for confirming that vulnerability scans are conducted. The CIO approved scanning tool(s) will be able to provide remediation suggestions and be able to associate a severity value to each vulnerability discovered based on the relative impact of the vulnerability on the affected system.

- As per WyIT - 2001 Information Classification policy, scan reports are classified as Confidential and shall be protected as such.

- State Agencies are required to provide all external IP addresses and Uniform Resource Locators (URLs) for all externally facing web applications to the CIO.

- Agencies will provide sufficient access to allow the vulnerability scan engine(s) to scan all services provided by the system. No devices connected to the network shall be specifically configured to block vulnerability scans from authorized scanning engines.

- Scans must be performed while in pre-deployment environments and periodically thereafter, as specified below:
    - Pre-deployment scans occur while systems or web applications are in a test and/or development environment:

        - All systems must undergo an authenticated internal infrastructure scan before being deployed to the production environment. Any infrastructure vulnerability discovered must be remediated or determined to be a false positive or insignificant risk by the respective agency security liaison and reviewed/approved by the CIO prior to deployment.

        - A designated service account may be required to assess a system's vulnerability(s) fully. When this type of authentication is required, scans must be run with the appropriate credentials encompassing each access level (e.g., user, admin).

        - Any system or application deployed to the production environment with un-remediated vulnerabilities must have a formal remediation plan and documented security exception approval from the CIO.

- Post-deployment scans occur the first time a system or web application is deployed in the State's Enterprise production environment.
    - Systems owners shall inform the CIO within 3 business days of implementation to determine an appropriate time to scan any newly deployed systems anywhere within the State's enterprise production environment. If the system is public-facing, both an internal and external vulnerability scan will be conducted.

- Recurring Scans: After the initial scan, the frequency of scans is to occur

according to the system or application risk rating (see Table 2 - Risk Rating).

- State assets are required to undergo recurring scans. Scans will be conducted, at a minimum, weekly unless a requesting agency has a validated security exception request approved by the CIO.
- All vulnerabilities found during scans must be addressed as per the remediation section below.

VII. DETERMINE RISK RATING AND FREQUENCY OF SCANS

The risk vulnerabilities pose to systems and applications is based on the likelihood of a vulnerability being exploited and the impact (i.e., high, moderate, or low) if the confidentiality, integrity, or availability of the information assets were compromised. The likelihood of a vulnerability being exploited is increased in direct relation to the systems or application's accessibility from other systems. (see Table 2 - Risk Rating).

TABLE 2 RISK RATING

Impact (Confidentiality, Integrity, Availability)	EXPOSURE		
	Systems with no network connectivity to production data	Systems with network connectivity to production data (not internet-facing)	System that is publicly available from the internet
High	Medium	High	High
Medium	Low	Medium	High
Low	Low	Low	Medium

The Minimum frequency of scans is dependent on the risk rating. Systems without a risk rating will be scanned as if they had a risk rating of "High" until they are rated.

TABLE 3 FREQUENCY OF SCANS

INFRASTRUCTURE SCANS	
Risk Rating	Frequency

High	Weekly
Medium	Bi-Monthly
Low	Monthly
WEB APPLICATION SCANS	
High	Quarterly or after significant change
Medium	Semi-annually
Low	Annually

VIII. REMEDIATION

Vulnerabilities discovered during scans will be remediated based on the risk rating and vulnerability severity identified from the Common Vulnerability Scoring System (CVSS) see Table 4 - Remediation Timeframes) denoted by the vulnerability scan results. If a highly exploitable and dangerous vulnerability is identified, the CIO may request an alteration to the action and timelines below.

TABLE 4: REMEDIATION TIMEFRAMES

CVSS QUALITY RANGING AND SCORE	ACTIONS AND TIMELINES
Critical CVSS 9.0 - 10.0	Patches shall be applied within 5 business days after the patching system has determined applicability. Security exceptions for patches shall be submitted within 10 business days. Failure to remediate will result in the machine being segregated from domain resources.

High CVSS 7.0 - 8.9	Patches shall be applied within 7 business days after the system has determined applicability. Security exceptions for patches shall be submitted within 14 business days. Failure to remediate will result in the machine being segregated from domain resources.
Medium CVSS 4.0 - 6.9	Patches shall be applied within 15 business days after the system has determined applicability. Security exceptions for patches shall be submitted within 30 business days. Failure to remediate will result in the machine being segregated from domain resources.
Low CVSS 0.1 - 3.9	Patches shall be applied within 30 business days after the system has determined applicability. Security exceptions for patches shall be submitted within 30 business days. Failure to remediate will result in the machine being segregated from domain resources.

- The CIO may review vulnerabilities to adjust the severity rating when required. Re-scanning of assets will be conducted to verify that remediation has been completed.

- Individuals managing vulnerability scans are required to notify and provide reports to the CIO within 3 business days of the initial request. Automated reports can be developed for scans and provided if so deemed necessary. A monthly automated report of un-remediated vulnerabilities on systems or applications which are running in production shall be provided if requested by the CIO.

- The CIO will notify the applicable agency director of any un-remediated vulnerabilities not addressed in the timeframes prescribed in this policy so that the appropriate party can accept the risk.

REFERENCES:

- WyIT - 2001 - Information Classification

Review/Approval:

Date Issued/Review Date

This policy shall be reviewed at least annually and updated / reviewed / approved as defined in the Office of Chief Information Officer (OCIO) Policy lifecycle.

Factors that may trigger an out of cycle review are:

- Significant changes in administrative, legal, or regulatory requirements;
- Results of cybersecurity incidents or operational audits;
- Findings from compliance reviews or gap assessments;
- Changes in State or Federal policies impacting audit logging obligations; or
- Introduction of new technologies or retirement of existing systems that impact audit requirements.

The review and update process shall be coordinated by Governance, Risk and Compliance (GRC), completed by the policy owner and approved through the OCIO policy review workflow.

Approval

This policy must be signed by the appropriate officer (listed below) before it is considered approved and put into force.

The review and update process shall be coordinated by the GRC team, completed by the policy owner and approved through the OCIO policy review workflow.

Jeff Clines	Director
Officer Name	Officer Title
_____	_____
Officer's Signature	Date

DOCUMENT HISTORY

ORIGINAL SUBMISSION				
SUBMITTED ON	**SUBMITTED BY**	**APPROVED BY**	**APPROVED BY DATE(S)**	**EFFECTIVE DATE**
June 2024	ETS Governance, Risk and Compliance	Public Comment Period	05/10/2024 - 05/24/2024	June 2024

REVISIONS			
REVISION DATE	**REVISED BY**	**SUMMARY OF REVISIONS**	**LAST APPROVED BY**
07/15/2026	ETS Governance, Risk and Compliance	Updated link(s) to the Security Exception Request Form to reflect a change in process.	June 2024

REVIEWS		
LAST REVIEW DATE	**LAST REVIEWED BY**	**NEXT REVIEW DATE**